



In2120 gruppetime 1 men korte notater

Språkteknologiske metoder (Universitetet i Oslo)

- Integritet handler om at data ikke blir slettet eller endre, for eksempel eksamenskarakter.
- «Konfidensialitet er egenskapen av at informasjon ikke blir gjort tilgjengelig eller vist til uautoriserte individer, entiteter eller prosesser.» tiltak er kryptering og
- Tilgjengelighet handler om at informasjon skal være der når vi faktisk trenger det. trusler kan være DoS/DDoS dvs at de ikke klarer å håndtere info.
- Sikkerhetstiltak kan være backup av info og kryptering, begrense adgang, sporbarhet, autosintisering, vektore og kamera(fysisk)
- Tilgangsautorisering og tilgangskontroll, tilgangsautorisering er at du bestemmer hvem som vil tilgang til info, tilgangskontroll, den sjekker at den riktig person som er der

Uka oppgaver:

- 1- I X.800 er autoriserin definert som å spesifisere tilgangspolicy, og som å gi tilgang. Da er definisjonen på konfidensialitet og integritet er i X.800 er meningsløse når autorisering defineres som at man blir autorisert i kraft av at man får tilgang, dvs i den betydning ville en angriper med et stjålet passord være autorisert, uten brudd på konfidensialitet, som er meningsløst. Konfidensialitet og integritet gir mening når autorisering kun defineres i betydning med å spesifisere tilgangspolicy.
- 2- Definisjon på autorisering som gjør konfidensialitet og integritet meningsfulle kan være at systemet gir tilgang basert på autorisasjonspolicy som på forhånd er definert av en autoritet(et menneske) eller delegerte. Å autorisere tilgang er en policy-prosess som foregår under konfigurasjonsfasen av IAM(identitets- og tilgangshåndtering) før brukeren får tilgang til systemet. Autoriseringsprosessen består av å definere tilgangsrettighetene som brukeren skal ha i henhold til jobbrolle.
- 3- Autorisering på wikipedia er definert som å spesifisere brukernes tilgangsrettigheter til dataressurser.
- 4- Ved å klart skille mellom det å spesifisere tilgangsrettigheter (autorisering) og å håndheve tilgangsrettigheter (tilgangskontroll) gjør Wikipedias definisjon på autorisering at ISO og X.800 sine definisjoner på 'konfidensialitet', 'integritet' og 'tilgjengelighet' blir meningsfulle. Uten dette skillet ville definisjonene bli meningsløse.
- 5- Sikkerhetspolicy for min laptop:
"Gjennom mitt juridiske eierskap av denne laptoppen, er kun jeg autorisert til å bruke den. På eksplisitte samtykke fra meg, kan jeg autorisere en bestemt annen person til å bruke min laptop for en begrenset tidsperiode, når jeg gjennom brukerautentisering låser den opp, og under mitt tilsyn lar personen få tilgang til Internett via en nettleser på laptoppen. Til enhver tid kan jeg tilbakekalle autorisasjonen ved å si dette til personen, som da gjør at personens bruk av min Laptop må opphøre øyeblikkelig". En slik policy er typisk hva vi forventer og antar, uten at vi nødvendigvis uttrykker den eksplisitt.
- 6- Eksempler på angrep som kan forårsake sikkerhetsbrudd for hvert KIT-sikkerhetsmål og mulige tiltak som forhindrer angrepene

a. Konfidensialitet.

Eksempel 1:

En student får tak i passordet til en foreleser som har laget eksamensoppgaver på en eksamensplattform. Studenten logger seg inn og får tilgang til eksamensoppgavene før eksamen. Dette er brudd på konfidensialitet. Et mulig tiltak er at foreleseren bruker et bedre passord og passer bedre på passordet sitt, eller at universitetet innfører tofaktor-autentisering.

Eksempel 2:

Phishing epost som ber brukeren logge på en konto, med lenke til falsk nettside for kontoen. Hvis brukeren lar seg lure får angriper tak i det hemmelige passordet, som i seg selv er brudd på konfidensialitet. Dette angrepet er ID-tyveri, og gjør angriperen istand til videre angrep. Mulige tiltak er styrking av sikkerhetskultur og bevissthet rundt denne typen angrep, slik at brukeren ikke så lett lar seg lure.

b. Integritet.

Eksempel 1:

En student som har gjort det dårlig på eksamen får tak i passordet til en administrator som legger karakterene inn i systemet. Studenten logger seg inn på systemet og gir seg selv karakter A, som er brudd på integritet. Et mulig tiltak er tofaktor-autentisering som gjør at det ikke er tilstrekkelig å bare stjele et passord for at en angriper skal få uautorisert tilgang.

Eksempel 2:

Et angrep på dataintegritet er f.eks. en falsk wifi-ruter som er man-in-the-middle mellom nettleser/klient og webtjener som kommuniserer med ukryptert http-forbindelse, der den falske ruter endrer på informasjon fra webtjeneren som vises i nettleseren. Mulig tiltak er kryptering av forbindelsen med https.

Eksempel 3:

Et angrep på systemintegritet er dataormer som automatisk sprer seg ved å utnytte sårbarheter i systemer, og på den måten infiserer stadig nye systemer. Et infisert system er et system som har mistet deler av sin integritet. Systemet kan fortsatt fungere til en viss grad, men med redusert integritet og pålitelighet. Mulige tiltak er å fjerne utrydde dataormen og fjerne sårbarhetene som utnyttet av dataormen slik at ikke systemet blir infisert igjen.

c. Tilgjengelighet.

Eksempel 1:

En student som ikke har forberedt seg til eksamen ønsker at hele eksamen skal bli avlyst. For få dette til leier han et bottnett og kjører et DDoS-angrep mot eksamensplattformen slik at ingen studenter får tilgang. Som følge av angrepet beslutter administrasjonen å avlyse eksamen og utsette den til en uke senere. Dette er et brudd på tilgjengelighet. Et mulig tiltak er å installere en moderne brannmur som klarer å filtrere bort DDoS-trafikk. Et annet tiltak er å styrke studentenes sikkerhetskultur og moralske dømmekraft slik at ingen finner på å sabotere eksamen.

Eksempel 2:

Et angrep på tilgjengelighet er løsepengevirus som f.eks. kommer inn via phishing e-post. Løsepengevirus krypterer filer slik at de ikke lenger er tilgjengelige for brukerne. I tillegg til å styrke sikkerhetskultur og bevissthet er et mulig tiltak å benytte antivirusprogramvare som detekterer og filtrerer bort løsepengevirus før det starter å kjøre. Et annet tiltak er å ha god backup.

Eksempel 3:

Et angrep på tilgjengelighet er hvis en utro tjener i et firma, eller en hacker, klarer å fjerne tilgangsautorisasjoner for en bruker. Det gjør at brukeren ikke lenger får tilgang til ressurser som brukeren egentlig skulle ha tilgang til. Mulige tiltak er å ha god kontroll på hvem som kan endre brukerrettigheter, og samtidig ha logging av all slik aktivitet for å kunne spore angrep til rette vedkommende.

7- Trusler mot konfigureringsfasen av IAM

Å kartlegge mulige trusler (dvs. mulige trusselscenarier) kalles «trusselmodellering». Det går i hovedsak utpå å beskrive mulige og relevante (tilsiktete/utisiktete) handlinger og hendelsesforløp som kan forårsake sikkerhetsbrudd.

a. Mulige trusler mot konfigurasjonsfasen av IAM er f.eks:

i. Brukeren registreres med feil navn.

ii. Brukeren er riktig registrert, men autentikatorene (f. eks passord eller brikke) sendes til feil person.

iii. Riktig registrering og klargjøring av autentikatorer, men det konfigureres altfor vid tilgangsautorisasjon, som ikke er i samsvar med autorisasjonspolicyen som gjelder for jobbrollen.

8- Trusler mot bruksfasen av IAM

i. Angripere kan gjette passord fordi svake passord er tillatt eller det ikke fins begrensninger på antall forsøk. Med cracket passord kan angriper logge inn.

ii. Biometrisk autentisering kan manipuleres på grunn av svak beskyttelse mot presentasjonsangrep (f.eks. å bruke gummifinger, eller å vise bilde av ansikt)

iii. Autentiserte brukere får uautorisert tilgang til ressurser fordi policy/regler for tilgangskontroll ikke håndheves korrekt og sikkert av systemet.

9- En bruker har autentisert seg til et nettsted på Internett ved starten av en økt, og sender data til webtjeneren via klientcomputeren. Forklar i hvilken grad tjenestetilbyder/webtjener kan ha visshet om at dataene som mottas i løpet av økten er autentisk sent av brukeren?

Brukerautentisering gir ikke nødvendigvis sterk garanti for data/meldingsautentisitet, dvs. at alle data som oversendes gjennom økten er basert på brukerens genuine intensjon. Det er

plausibelt at brukeren forlater klientcomputeren uten å låse den, f.eks. for å ta en kaffe eller gå på toalettet, og at en annen person urettmessig bruker computeren til å sende data til webtjeneren. En annen plausibel mulighet er at klientcomputeren er infisert med en trojaner som genererer og sender data til serveren uten brukerens viten, selv om brukeren kanskje fysisk sitter foran computeren.

Hvis økten mellom klient og webtjener ikke er beskyttet med https/TLS (Transport Layer Security) eller noen andre VPN (Virtual Private Network)-løsning, så er det plausibelt at et mann-i-midten-angrep kan skje, som dermed kan endre eller slette data som utveksles mellom nettleser og webtjener.